NORTHSTAR TECHNOLOGIES PVT. LTD.

Incident Response SOP

Standard operating procedure for reporting, triaging, containing, investigating, and recovering from security and technology incidents

Document ID	IT-SOP-002
Document Type	SOP
Access Scope	TEAM_ONLY
Department	IT Operations / Security
Version	1.0
Effective Date	04 November 2026
Process Owner	IT Operations and Security Team
Classification	Internal – Restricted Operational Procedure

INTERNAL TEAM PROCEDURE

This fictional demonstration SOP is prepared for Northstar Technologies Pvt. Ltd. and OnBoardIQ document-ingestion testing. It is illustrative and does not replace an approved security incident response plan, legal advice, or applicable notification obligations.

1. Purpose

This SOP establishes a coordinated process for handling suspected or confirmed information security, privacy, infrastructure, application, and service availability incidents. The objectives are to protect people and information, limit impact, restore services safely, preserve evidence, and capture lessons for prevention.

- Provide a clear reporting route for employees and technical teams.
- Enable consistent severity assessment, escalation, and incident ownership.
- Contain threats and service impact without unnecessarily destroying evidence.
- Coordinate investigation, recovery, internal communications, and required notifications.
- Maintain an auditable record and improve controls after incidents.

2. Scope and Access Restriction

This procedure applies to incidents involving company-managed systems, accounts, endpoints, networks, cloud services, applications, databases, business information, and third-party services used by Northstar Technologies Pvt. Ltd. It covers suspected events as well as confirmed incidents.

- Security incidents: malware, phishing, credential compromise, unauthorized access, data exposure, and suspicious activity.
- Technology incidents: service outages, infrastructure failures, data corruption, and major performance degradation.
- Privacy-related incidents: loss, unauthorized disclosure, or improper access to personal or confidential information.

Access restriction: This document is classified as TEAM_ONLY for the IT Operations / Security department. OnBoardIQ should enforce access using the matching department ID and the application's RBAC rules. General employees should use the approved incident-reporting channel rather than relying on access to this operational playbook.

3. Definitions

Term	Meaning
Event	An observable occurrence in a system, service, or environment that may be relevant to security or operations.
Incident	An event or series of events that has or may have compromised confidentiality, integrity, availability, or service operation.
Severity	A classification based on impact, urgency, scope, and potential harm.
Incident Lead	The person coordinating response activities, decisions, status updates, and closure.
Containment	Actions taken to limit the incident's spread or ongoing impact.
Evidence	Logs, alerts, files, records, system images, or other information relevant to understanding an incident.
Root cause	The underlying condition or failure that allowed the incident to occur.

4. Roles and Responsibilities

Role	Responsibilities
Reporter	Report suspected incidents promptly, provide known facts, and avoid investigating beyond safe instructions.
Service Desk / IT Operations	Receive reports, create incident records, perform initial triage, and route incidents to the correct responders.
Incident Lead	Coordinate response, assign tasks, maintain timeline, assess escalation needs, and approve operational closure.
Security Response Team	Investigate security indicators, assess compromise, recommend containment, and coordinate security recovery.
System / Application Owner	Provide technical context, assess affected services and data, implement approved remediation, and validate recovery.
Privacy / Legal Contact	Assess privacy and legal obligations and advise on required notifications and evidence handling.
Management	Support major incident decisions, resource allocation, and approved internal or external communications.

5. Reporting an Incident

Anyone who suspects an incident should report it promptly through the designated IT service desk, security reporting channel, or emergency escalation route published by the company. If the primary channel is unavailable, use the approved alternate contact method.

- Provide the time detected, affected system or account, observed symptoms, and actions already taken.
- Include relevant screenshots, alert identifiers, message headers, or error references when safe and appropriate.
- Do not include passwords, MFA codes, private keys, or unnecessary personal information in the report.
- Do not delete suspicious messages, files, or logs unless instructed by the response team.
- Do not forward suspected malware or sensitive information to personal accounts.
- If there is immediate risk to people, physical safety, or critical operations, use the applicable emergency procedure first.

6. Initial Triage and Incident Record

The receiving team creates an incident record and determines whether the report requires incident response, routine service support, or further investigation.

- Assign a unique incident reference and record the reporter, detection time, and intake channel.
- Identify affected services, accounts, devices, locations, data types, and business processes where known.
- Record observable facts separately from assumptions or unverified reports.
- Check available alerts, monitoring data, recent changes, and related incidents.
- Assign an initial severity and an Incident Lead for incidents requiring coordinated response.
- Preserve the original report and record subsequent decisions and actions in chronological order.

7. Severity Classification and Escalation

The following illustrative severity model supports prioritization. The Incident Lead may raise severity when uncertainty, potential harm, or business criticality warrants it. Applicable company escalation targets should be maintained in the operational contact directory.

Severity	Typical indicators	Response approach
SEV 1 – Critical	Confirmed widespread compromise; suspected major data exfiltration; critical service unavailable; safety or material business impact.	Immediate escalation to security leadership and management; coordinated response and frequent status updates.

Severity	Typical indicators	Response approach
SEV 2 – High	Significant service degradation; compromised privileged account; suspected exposure of sensitive data; multiple systems affected.	Urgent response by relevant technical owners; containment and management notification.
SEV 3 – Medium	Limited system or user impact; suspicious activity with no confirmed broad compromise; recoverable service disruption.	Assigned responder investigates and resolves; provide updates to affected stakeholders as appropriate.
SEV 4 – Low	Isolated low-impact event, blocked attempt, or minor issue with no material service or data impact.	Track, assess, and resolve through normal operational workflow.

- Escalate immediately if the incident involves privileged accounts, regulated or sensitive information, ransomware, suspected exfiltration, or a critical business service.
- Do not downgrade severity solely because the incident is difficult to investigate or has temporarily stopped.
- Record the reason and approver for material severity changes.

8. Containment

Containment aims to limit ongoing impact while preserving the ability to investigate. Actions must be proportionate, authorized, and documented.

- Isolate affected endpoints or workloads from networks when justified and approved by the Incident Lead or authorized responder.
- Disable or restrict compromised accounts, revoke sessions, rotate exposed credentials, and invalidate affected tokens as appropriate.
- Block malicious domains, IP addresses, hashes, or indicators using approved security controls where reliable.
- Pause affected integrations, deployments, jobs, or access paths if they are contributing to the incident.
- Preserve relevant logs, volatile evidence, and system state before destructive actions when feasible.
- Coordinate containment with system owners to avoid unnecessary disruption to unrelated services.
- Record the action, executor, timestamp, rationale, and observed result.

9. Investigation and Evidence Handling

- Establish an incident timeline using reliable timestamps and identify the systems or accounts involved.
- Review relevant authentication logs, endpoint alerts, network telemetry, application logs, database audit records, and cloud activity.
- Determine likely entry point, scope, affected assets, data exposure, persistence, and lateral movement where relevant.
- Use approved forensic methods and tools; avoid changing original evidence unnecessarily.
- Record evidence source, collection time, collector, storage location, and any transfer or access.
- Restrict evidence to authorized responders and protect it from alteration or unauthorized disclosure.
- Document confidence levels and distinguish confirmed findings from working hypotheses.
- Escalate potential personal-data exposure or legal implications to the designated privacy or legal contact.

10. Eradication and Remediation

- Remove malicious artifacts, unauthorized accounts, persistence mechanisms, and compromised configurations.
- Patch exploited vulnerabilities or apply approved compensating controls.
- Rotate credentials, keys, certificates, and tokens that may have been exposed.
- Rebuild or restore affected systems from trusted sources when integrity cannot be established.
- Validate that the initial attack path and related weaknesses have been addressed.
- Obtain system-owner and security approval before declaring eradication complete.

11. Recovery and Service Restoration

- Restore services from known-good backups or trusted deployment artifacts where required.
- Confirm data integrity, application functionality, access controls, and monitoring before returning systems to normal operation.
- Restore connectivity or user access in stages where practical and monitor for recurrence.
- Communicate expected service status and any temporary restrictions to affected stakeholders.
- Keep heightened monitoring in place for a period determined by the Incident Lead and system owner.
- Record recovery validation, outstanding risks, and the person approving service restoration.

12. Communications and Notifications

- The Incident Lead coordinates internal status updates and identifies the audiences that need information.
- Use approved communication channels and share only information necessary for the recipient's role.
- Do not speculate about cause, attribution, data exposure, or impact in broad communications.
- External statements, customer notifications, regulator communications, and legally required notices must be coordinated with authorized management and the designated legal/privacy contacts.
- Record what was communicated, to whom, by whom, and when.
- Do not disclose sensitive investigation details or personal information through public or informal channels.

13. Closure Criteria

An incident may be closed when the Incident Lead confirms that response objectives have been met and remaining risks have an accountable owner.

- The threat or service failure is contained and no longer causing uncontrolled impact.
- Affected systems have been recovered or a documented service plan is in place.
- Relevant evidence and the incident timeline are retained in the approved location.
- Required stakeholder communications and escalations have been completed.
- Follow-up actions have owners, priorities, and target dates.
- The closure summary records impact, cause where known, actions taken, recovery status, and residual risks.

14. Post-Incident Review and Lessons Learned

For major or recurring incidents, the Incident Lead coordinates a post-incident review after immediate response activities are complete. The review should focus on learning and control improvement rather than blame.

- Summarize what happened, when it happened, how it was detected, and how it was resolved.
- Identify root causes and contributing factors where evidence supports them.
- Assess detection speed, escalation, decision-making, communication, and recovery effectiveness.
- Document what worked well and what should change.
- Create tracked corrective actions for technical controls, process gaps, training, or monitoring.
- Assign action owners and due dates, then review completion through the normal governance process.

15. Readiness, Training, and Testing

- Maintain current incident contacts, escalation paths, system ownership information, and service dependencies.
- Ensure responders know how to access approved logs, monitoring systems, evidence storage, and response tools.
- Conduct periodic tabletop exercises for scenarios such as phishing, account compromise, ransomware, data exposure, and service outage.
- Review lessons from exercises and update playbooks, monitoring, and training accordingly.

- Verify that backup and recovery procedures are tested by the responsible system owners.

16. Records, Confidentiality, and Access

- Maintain incident records in approved service management or security systems.
- Limit access to incident details and evidence based on role and legitimate response need.
- Do not store credentials, private keys, or unnecessary personal data in incident tickets.
- Preserve records according to approved retention, legal hold, and evidence-handling requirements.
- Report suspected unauthorized access to incident records or evidence as a security incident.

OnBoardIQ metadata: Use access_scope TEAM_ONLY and the IT Operations / Security department ID. Retrieval must also enforce the user's authenticated role and department membership; the metadata label alone is not an authorization control.

17. Response Checklist

Checkpoint	Expected evidence
Report received	Incident reference, reporter, detection time, and initial facts recorded.
Triage completed	Affected assets, initial scope, severity, and Incident Lead identified.
Escalation completed	Required technical, management, privacy, or legal contacts notified.
Containment applied	Approved containment actions recorded with timestamps and owners.
Investigation performed	Timeline, findings, evidence sources, and confidence documented.
Eradication completed	Threat removed and relevant weaknesses addressed.
Recovery validated	Service, data integrity, access, and monitoring checked.
Closure and review	Summary, residual risks, and tracked follow-up actions recorded.

18. Ownership and Review

The IT Operations and Security Team owns this SOP. The process owner is responsible for maintaining response roles, escalation contacts, incident record requirements, and supporting playbooks. System owners are responsible for keeping service recovery information current.

This SOP should be reviewed periodically and after major incidents, exercises, material technology changes, or changes to applicable requirements. Updates require approval from the designated IT/security authority.

Document control: IT-SOP-002 | Version 1.0 | Effective 04 November 2026 | Access Scope: TEAM_ONLY | Department: IT Operations / Security

Demo notice: Northstar Technologies Pvt. Ltd. is a fictional company. This SOP is illustrative and does not replace an approved incident response plan, legal advice, or mandatory reporting requirements.